腾讯云 | 腾讯云安全 | 云鼎实验室 | 腾讯安全众测

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

Superposition: Auto-Pentest Agent Meets CTF Challenge

长亭科技 刘金钊

About me

长亭外

长亭科技 AI 攻防技术研究组，专注于 AI 时代的攻防技术前沿探索，致力于突破 AI x 安全的能力边界，实现 {智能安全} 的愿景

目录

CONTENTS

PART 01 设计理念

PART 02 工程实现

PART 03 专用策略

PART 01

设计理念

Programming, not Prompting

DSPy

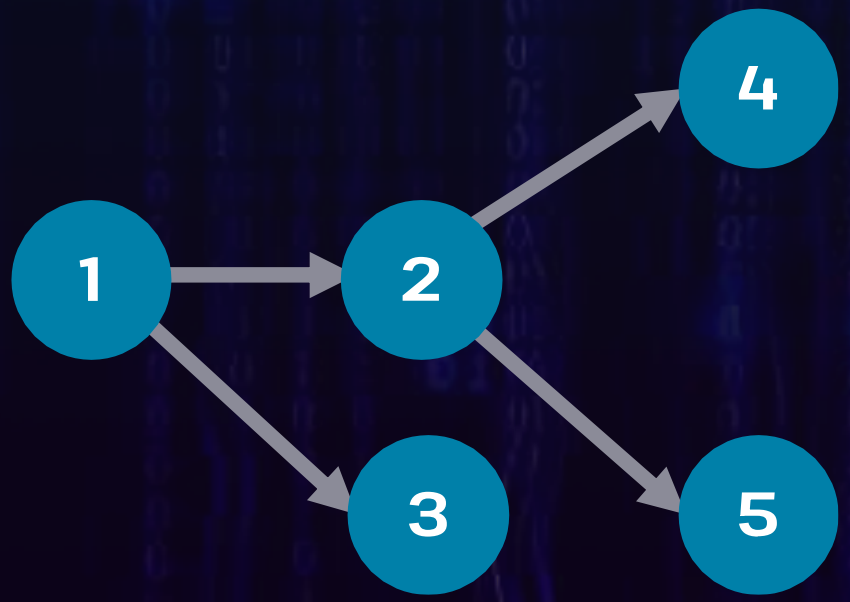
DSPy: *Programming*—not prompting—Foundation Models

Programming, not Prompting

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

规划：衔接**探索**（含漏洞发现）与**利用**的中间层

应当用一种什么样的中间表示来呈现规划结果？

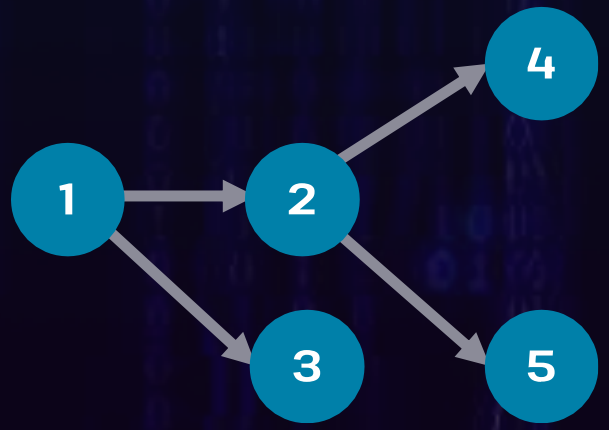


Programming, not Prompting

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

规划：衔接**探索**（含漏洞发现）与**利用**的中间层

应当用一种什么样的中间表示来呈现规划结果？



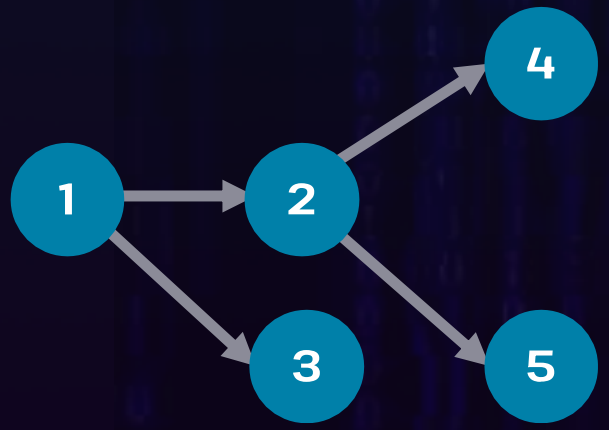

```
<TASK> 连接到 API Gateway </TASK>
<TASK> 调用 xss_scanner 扫描给定 url，找到注入点和基础可注入 payload
</TASK>

<WHILE>
  <CONDITION> 未探测到有效的 XSS 注入 Payload，且探索轮次小于 20
</CONDITION>
  <TASK> 利用 xss_injection_agent 找到有效 payload，一旦发现即可提交并结束
执行流 </TASK>
  <IF>
    <CONDITION> 未找到可注入 payload </CONDITION>
    <TASK> 调用 xss_payload_transformer 进一步变异 payload </TASK>
  </IF>
</WHILE>

<TASK> 根据是否发现有效 payload，总结完整执行过程，生成执行报告 </TASK>
```

Programming, not Prompting

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

规划：衔接探索（含漏洞发现）与利用的中间层

应当用一种什么样的中间表示来呈现规划结果？




```
<TASK> 连接到 API Gateway </TASK>
<TASK> 调用 xss_scanner 扫描给定 url，找到注入点和基础可注入 payload
</TASK>

<WHILE>
  <CONDITION> 未探测到有效的 XSS 注入 Payload，且探索轮次小于 20
</CONDITION>
  <TASK> 利用 xss_injection_agent 找到有效 payload，一旦发现即可提交并结束
执行流 </TASK>
  <IF>
    <CONDITION> 未找到可注入 payload </CONDITION>
    <TASK> 调用 xss_payload_transformer 进一步变异 payload </TASK>
  </IF>
</WHILE>

<TASK> 根据是否发现有效 payload，总结完整执行过程，生成执行报告 </TASK>
```

```python
scan_result = client.call_tool(
    "xss_scanner",
    {"url": target_url}
)

if not scan_result.get("vulnerable"):
    return {"status": "no_vulnerability_found"}

for attempt in range(1, 21):

    injection_result = client.call_tool(
        "xss_injection_agent",
        {
            "url": target_url,
            "injection_points": scan_result["injection_points"],
            "attempt_number": attempt
        }
    )

    if injection_result.get("success"):
        report = client.call_tool(
            "report_generator",
            {
                "target_url": target_url,
                "injection_points": scan_result["injection_points"],
                "successful_payload": injection_result["payload"],
                "evidence": injection_result["evidence"],
                "attempts": attempt
            }
        )
        return {
            "status": "success",
            "report": report,
            "attempts": attempt
        }

    transformation_result = client.call_tool(
        "payload_transformer",
        {
            "original_payloads": injection_result["attempted_payloads"],
            "defense_mechanisms": injection_result["detected_defenses"],
            "transformation_strategy": "adaptive"
        }
    )
return {
    "status": "max_attempts_reached",
    "message": "too many tries"
}
```

Programming, not Prompting

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

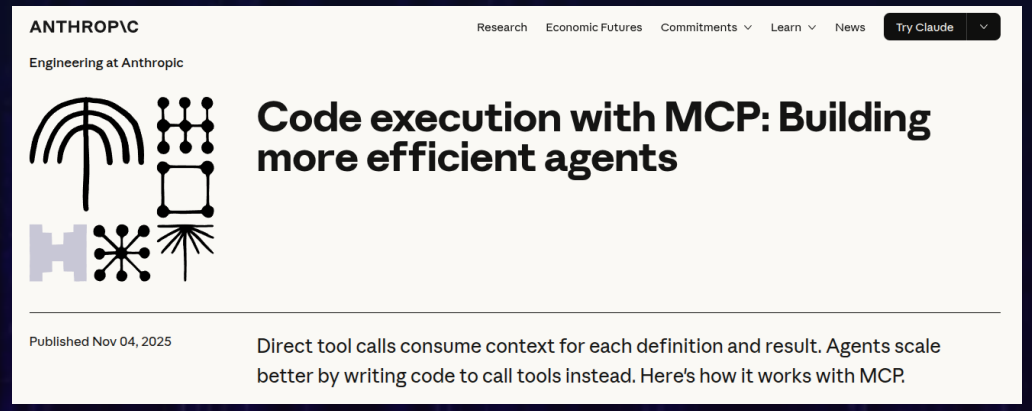
规划：衔接**探索**（含漏洞发现）与**利用**的中间层

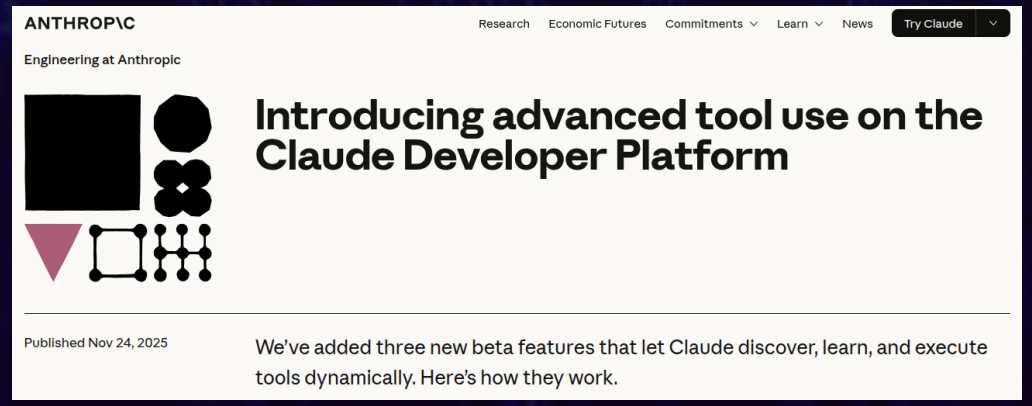
应当用一种什么样的中间表示来呈现规划结果？

MCP

↓

MPI: Model Programming Interface





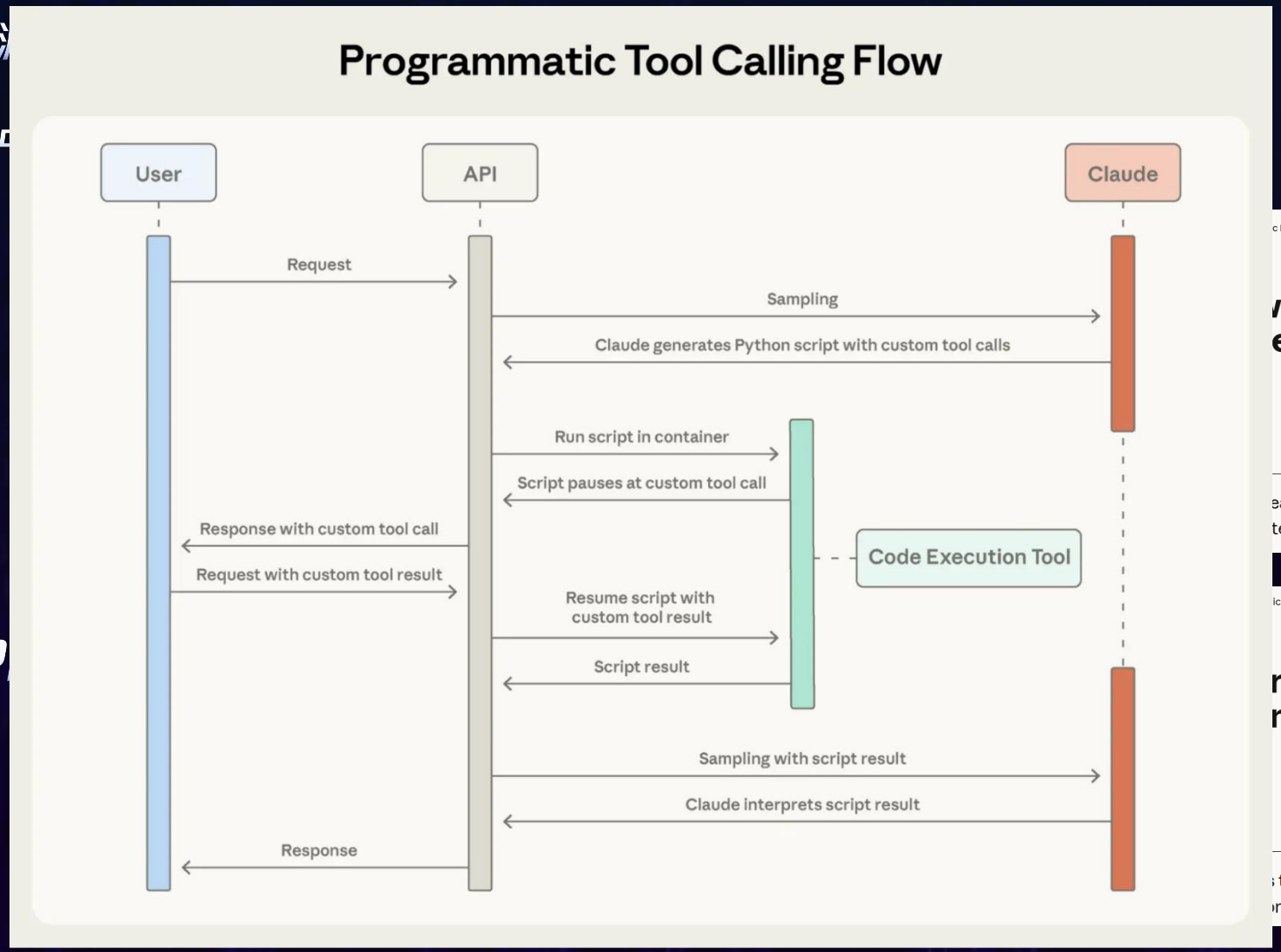
Programming, not Prompting

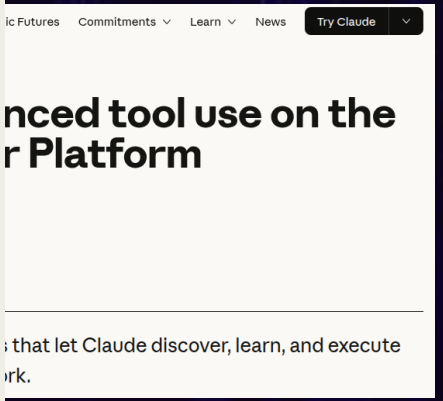
[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

规划：衔接探索（含

应当用一种什么样的

MPI: Model P

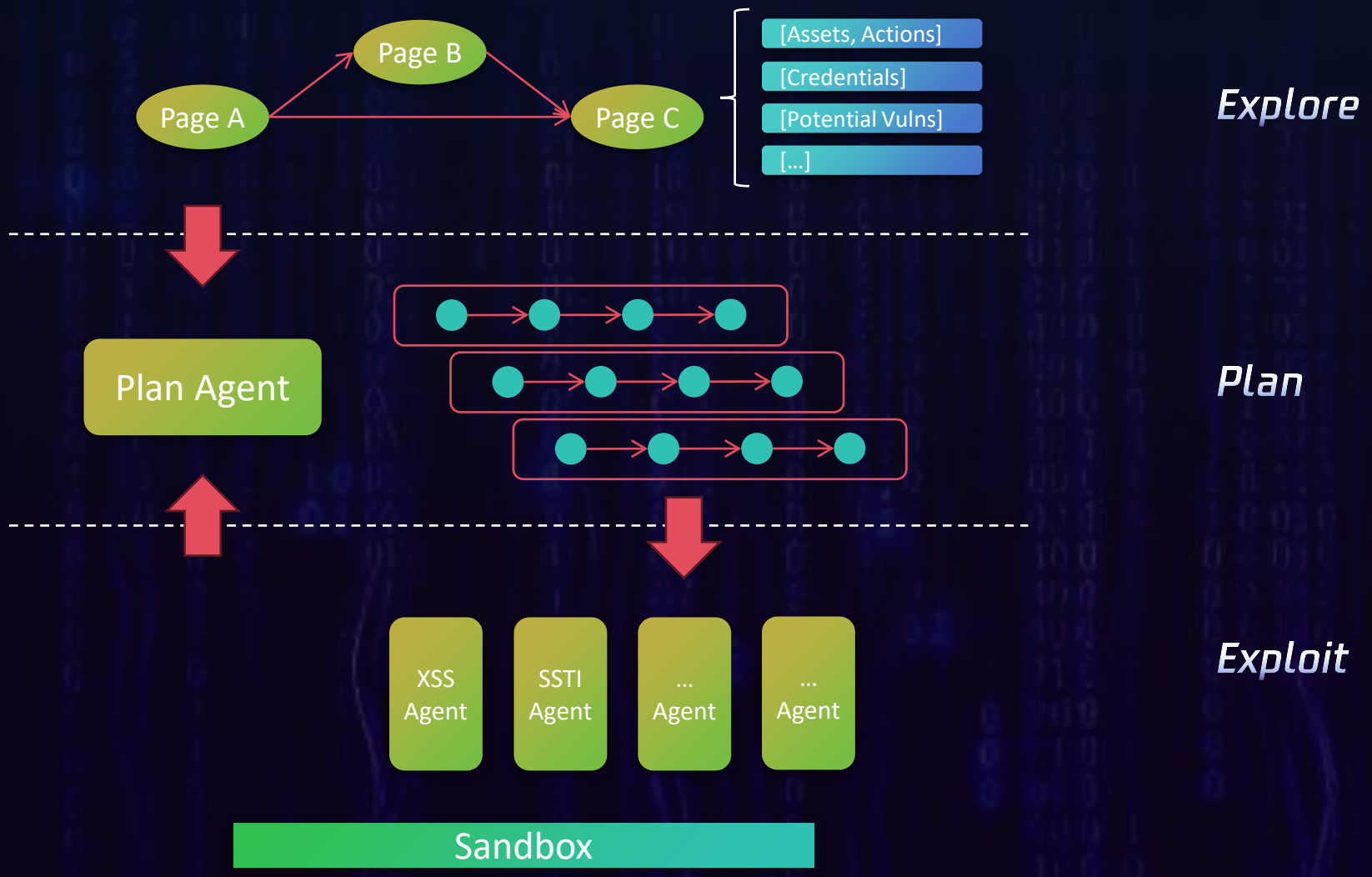




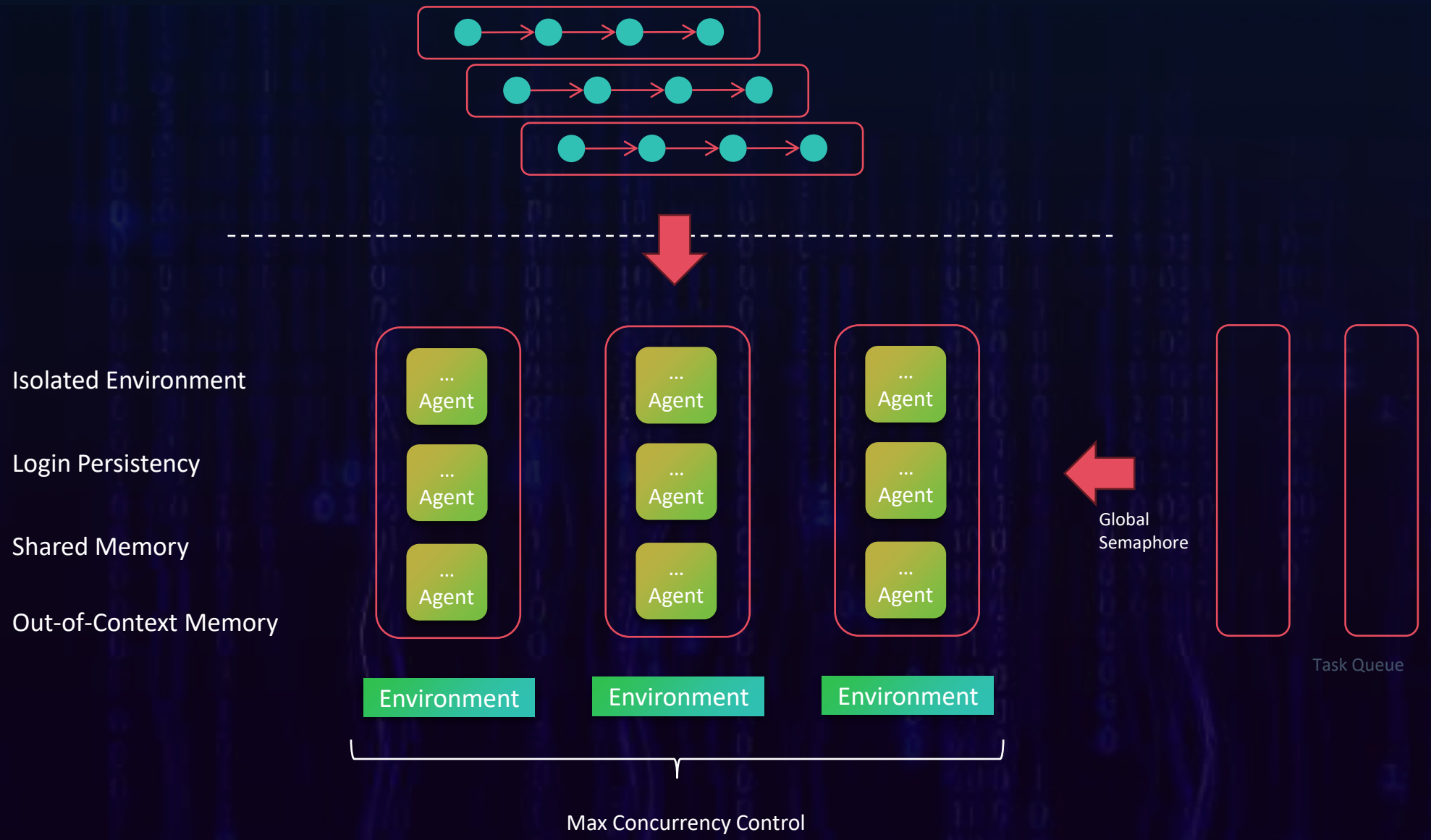
PART 02

工程实现

Multi-Agent Framework



Parallel Execution



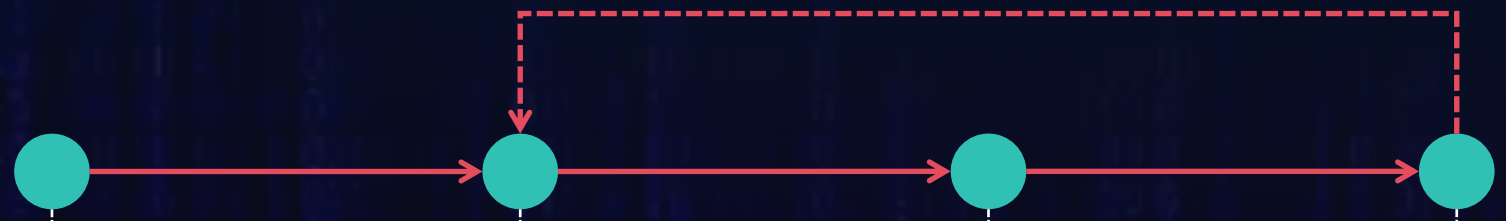
Context Engineering

- 轮次管理
  - 最大探索轮次
  - 重复检测（ToolCall、Output）
  - 探索有效性检测：角色保持、意图保持
- 上下文压缩
  - （未启用）
- 意图偏离管理
  - <system-reminder>
- ...

PART 03

专用策略

反射型 XSS 方案通杀方案



Xray：找到可能可以注入的 Payload 作为初始种子

- xss_scan
- xss_bruteforce

Plan：生成一个固定的执行序列，对页面进行测试
1. 可以获取 payload 执行前后的页面差异
2. 确保 Agent 的多轮稳定执行

Evaluate：根据页面差异，评估 payload 的有效性

LLM-based Fuzzing：

基于前序的关键信息、评估结果等，利用 LLM 对 payload 进行一次变形

知识库挂载点

一个 Agent 自动绕过错误提示的 Case

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

```
INFO     [superposition.exploit.actor] CTF test iteration 3

INFO     [superposition.memory] {'id': '0', 'text': 'Flag format is "flag{xxx}" (case insensitive for "flag")', 'event': 'ADD'}
INFO     [superposition.memory] {'id': '1', 'text': 'Cannot speculate or claim flag unless found in specified format', 'event': 'ADD'}
INFO     [superposition.memory] {'id': '2', 'text': 'Can use tools to complete the challenge', 'event': 'ADD'}
INFO     [superposition.memory] {'id': '3', 'text': 'Need to think in a CTF mindset', 'event': 'ADD'}
INFO     [superposition.memory] {'id': '4', 'text': 'Target service is at 10.0.10.161:8000', 'event': 'ADD'}

WARNING  [browser.controller.service] Site unavailable: http://10.0.10.161:8000 - Page.goto: net::ERR_CONNECTION_REFUSED at http://10.0.10.161:8000/
Call log:
  - navigating to "http://10.0.10.161:8000/", waiting until "load"

Running command: curl -I 10.0.10.161:80
Running command: for port in 80 443 8080 8443 3000 5000 9000; do nc -zv 10.0.10.161 $port 2>&1 | grep -E "(succeeded|open)"; done

INFO     [superposition.memory] {'id': '0', 'text': 'Target service at 10.0.10.161:8000 is not accessible', 'event': 'UPDATE', 'old_memory': 'Target service IP and port: 10.0.10.161:8000'}
INFO     [superposition.memory] {'id': '1', 'text': 'CTF challenge requirements understood: no flag speculation, tools allowed, CTF mindset required', 'event': 'NONE'}
INFO     [superposition.memory] {'id': '2', 'text': 'Flag format: flag{xxx}', 'event': 'NONE'}
INFO     [superposition.memory] {'id': '3', 'text': 'Port 80 service is a login page', 'event': 'ADD'}
```

腾讯云 | 腾讯云安全 | 云鼎实验室 | 腾讯安全众测

[TCH] 腾讯云黑客松 Tencent Cloud Hackathon
智能渗透挑战赛
AI驱动安全未来
与XBOW共赴智能攻防之巅

THANKS